Security Incident Response Policy

Version: 2.3

Effective Date: 2026-01-15

Scope

This policy covers security incidents broadly — not just the phishing-email reporting already covered in the IT Security Policy (report within 24 hours). It defines severity levels and response timeframes for all incident types: data breaches, malware, lost devices, unauthorized access, and physical security incidents.

Severity Levels

Level	Definition	Initial Response
SEV-1 (Critical)	Active breach, customer data exposed	1 hour
SEV-2 (High)	Malware, unauthorized access attempt	4 hours
SEV-3 (Medium)	Lost device, policy violation	24 hours
SEV-4 (Low)	Suspicious activity, no confirmed impact	3 business days

Note: a lost work laptop is SEV-3 under this policy's general response timeline, but the IT Security Policy's own 24-hour reporting requirement for lost laptops still applies — report it within 24 hours regardless of which severity level it's later classified as.

Reporting an Incident

Report suspected incidents to the Security Operations channel or security@company (fictional) immediately — do not wait to confirm severity yourself; the security team classifies it.

Breach Notification

For incidents involving Restricted data (per the Data Privacy Policy's classification), the Data Protection Officer must be notified within **2 hours** of discovery, separate from and in addition to the general incident-reporting step above.

Post-Incident Review

Every SEV-1 or SEV-2 incident gets a post-incident review within **5 business days** of resolution, documenting root cause and remediation. Reviews are retained for **2 years**, per the Data Privacy Policy's retention schedule for security logs.